

University of Wah

Department of Computer Science



Submit to:

Ms. Wasifa Kanwal

Submit by:

Muhammad Talha

Course:

Information and Security Lab - CS-251L

Reg No:

UW-24-CS-BS-101

Section:

BS-CS-3rd-B

-: Tech Nova College :-

Risk Management:

	Risk Description	Who is Affected	Possible Impact
1.	Student Data Loss	Students	Malware,
2.	Biometric Integrity	Students, staffs	Machine effect
3.	Data leak for students	Students, IT staffs	Exposure of personal info
4.	Receive spam email due to data loss	Students	Gmail compromise
5.	Student network Slow	Student, IT dep	Network slow down

Information Security Policy:

1: Purpose:

This policy aims to protect TechNova information, Integrity, Availability of data, ensure confidentiality of student and staff data, maintain system availability,

2: Scope

Policy apply to all faculty, students, Wi-Fi networks email accounts.

3: Roles and Responsibility:

Management team: Approve policies, allocate budgets, teach staff and student about policies.

College IT dep: Maintain systems, apply updates, monitor networks, manage access controls.

College Staff: Follow acceptable use rules, secure passwords, protect institutional data.

Students: Open emails carefully, follow Wi-Fi rules, avoid unauthorized

4. Acceptable Use Policy

Rules for using:

Lab computers Internet & Wi-Fi Official email Removable media Specify what is allowed and what is not allowed.

Lab Systems:

Only academic software allowed; no games or hacking tools. Internet/Wi-Fi: No illegal downloads, harmful browsing, or bypassing filters.

Email Use:

Only for academic or official purposes; avoid forwarding spam. USB Devices: Only allowed after antivirus scan; avoid unknown USB drives

Password Policy:

Minimum 10-character alphanumeric password.

Data Protection and Privacy:

Unauthorized access should be monitored on all records and databases.

Email and Communication Policy:

Awareness should be spread about safe email practices such as not clicking suspicious emails.

Overseas Login Attempts:

Multiple login attempts from foreign IPs should be blocked immediately and the affected account must be secured.

Unauthorized Student Data Downloads:

Any unauthorized download of student profiles must be reported to admins and restricted to authorized staff only.

Compromised Staff Email:

If a staff email sends spam automatically, the account should be disabled until the password is reset and the device is checked.

Internet Misuse in Labs:

Downloading movies on lab PCs is not allowed and students misusing internet resources should receive warnings or lose access.

Missing Biometric Logs:

Missing biometric logs must be reported immediately and the system checked for errors or tampering.

Incident Reporting:

Any incident (virus, malware, misuse) should be reported to faculty and admins.

Policy Enforcement:

If someone is not following policies they will receive a warning, and repeated violation may result in a fine.

6 Month Awareness Program:**1. Objectives**

- Reduce phishing-related incidents among staff and students.

- Promote secure password practices and safe use of lab PCs.
- Increase awareness of how information security impacts daily academic and professional life.
- Improve understanding of biometric systems and database security.
- Encourage active participation in campus-wide security awareness seminars.

2. Target Audience

- Faculty
- Administrative Staff
- Students
- IT

3. Training / Awareness Activities

- Awareness sessions on information security.
- Training on biometric systems, database basics, and lab PC usage.
- Awareness on spam emails, phishing, and safe internet practices.

4. Schedule

Month 1: Awareness on biometric system, database basics, and proper lab PC usage for students and staff.

Month 2: Basic information security awareness (spam emails, phishing, safe browsing) for students and staff.

Month 3: Session on how information security programs impact daily life for students.

Month 4-6: Awareness seminars for students, faculty, and IT.

5. Evaluation / Measurement

- Quiz scores before and after training sessions.
- Results from optional phishing simulation exercises.
- Attendance records for monthly workshops and seminars.
- Feedback forms from students, faculty, and staff.
- Reduction in reported security incidents or misuse cases.

Map to ISO+NIST: ISO MAPPING

ISO 27001 Mapping

Policy Element	Related ISO 27001 Category
Overseas Login Attempts	A.5.15 Access Control A.5.17 Authentication Information
Unauthorized Student Data Downloads	A.5.12 Classification of Information A.5.34 Privacy and Protection of PII
Compromised Staff Email	A.5.15 Access Control A.5.17 Authentication Information

Internet Misuse in Labs	A.5.10 Acceptable Use of Information and Other Associated Assets A.8.23 Web Filtering
Missing Biometric Logs	A.5.24 Information Security Incident Management Planning and Preparation A.8.24 Use of Cryptography
Password Policy	A.5.15 Access Control A.5.17 Authentication Information A.8.5 Secure Authentication
Awareness Program	A.6.3 Information Security Awareness, Education and Training A.5.7 Threat Intelligence

NIST Mapping

Policy Element	NIST Function
Overseas Login Attempts	Detect
Unauthorized Student Data Downloads	Protect
Compromised Staff Email	Detect / Respond
Internet Misuse in Labs	Detect / Protect
Missing Biometric Logs	Detect / Respond / Recover

Case Study 1:

1. Ethical dilemma & conflicting values:

The technician must choose between respecting the faculty member's reputation/privacy and protecting exam integrity and system security.

2. Applicable legal principles:

Privacy laws, acceptable-use policies, institutional IT security policies, and rules against unauthorized access to confidential material (exam papers).

3. Recommended professional action:

As the faculty's email was used, the technician should officially report the incident. An authorized investigation should check whether the download was done by the faculty member or by an unauthorized user. The technician should **not** secretly investigate on his own.

Case Study 2:

1. Ethical dilemma & conflicting values:

Balancing academic research interests vs. students' right to privacy and informed consent.

2. Applicable legal principles:

Data protection laws, privacy regulations, consent requirements, and institutional policies regarding the handling of personally identifiable information.

3. Recommended professional action:

It is not acceptable for a faculty member to export and use private student data without consent or formal approval. The issue should be reported to the appropriate authority (data protection office or administration). The faculty member must obtain proper ethical approval and anonymize data before using it.

Case Study 3:

1. Ethical dilemma & conflicting values:

Balancing the intern's career and learning opportunity vs. protecting students' privacy and maintaining trust in the IT department.

2. Applicable legal principles:

Privacy laws, acceptable-use policies, unauthorized access rules (IT security policies), and confidentiality principles.

3. Recommended professional action:

Even if no harm was done, reading private emails is a serious violation. The incident must be reported to management because unauthorized access cannot be ignored. After reporting, management can decide on corrective action, which may include formal training and a warning rather than firing, but it should not be hidden by the technician.